

Fluvia Independent Audit v1

Informe oficial de auditoría independiente

Proyecto: Fluvia

Repositorio: <<https://github.com/celestinojbm/Fluvia.git>>

Línea base auditada: inferida desde el HEAD clonado, porque la rama/tag/SHA fueron entregados como placeholders.

Rama detectada: claude/new-session-hae07h

Commit auditado: a665b4ff6a8dca5e64e786b534ce1f2da85455f2

Fecha del commit: 2026-07-04T17:57:39Z

Fecha de auditoría: 2026-07-04

Modo: solo lectura; no se modificó el repositorio de Fluvia ni se instalaron dependencias.

Tabla de contenido

- Fluvia Independent Audit v1
- Instrucciones ejecutivas para el constructor
- 1. Veredicto ejecutivo
- Veredicto final
- 2. Estado real
- Funcional y verificado en esta auditoría
- Funcional parcialmente, verificado por inspección estática pero no por ejecución completa
- Simulado
- Placeholder
- Documentado pero no implementado
- Implementado pero no probado por esta auditoría
- Fallido
- Bloqueado
- No evaluable
- 3. Inventario técnico
- Aplicaciones
- Paquetes
- Servicios y bases de datos
- Infraestructura
- Dependencias directas externas
- 4. Hallazgos priorizados
- P1 - Alto / bloqueante por área
- P2 - Medio / siguiente ciclo
- P3 - Bajo / mejoras recomendables
- 5. Matriz requisito contra implementación
- 6. Análisis del prompt maestro
- Instrucciones que deben mantenerse
- Instrucciones demasiado rígidas
- Instrucciones o decisiones inconvenientes
- Instrucciones faltantes
- Decisiones que deben quedar a criterio del constructor
- Correcciones recomendadas al prompt/proceso
- 7. Riesgos
- Financieros
- Técnicos
- Seguridad
- Multi-tenant
- Operativos
- Regulatorios/compliance

- Datos
- Dependencias
- Continuidad
- 8. Deuda técnica
- Deuda aceptable
- Deuda que bloquea
- Deuda que empeorará rápidamente
- Deuda que puede posponerse
- 9. Plan de remediación
- 10. Próxima secuencia recomendada
- Qué corregir primero
- Qué conservar
- Qué eliminar o desactivar temporalmente
- Qué refactorizar
- Qué no construir todavía
- Qué puede continuar en paralelo
- Decisiones humanas necesarias
- Cuándo volver a auditar
- Plan de incorporación de hallazgos al desarrollo activo
- Backlog de remediación
- AUD-P1-001
- AUD-P1-002
- AUD-P1-003
- AUD-P1-004
- AUD-P1-005
- AUD-P1-006
- AUD-P1-007
- AUD-P1-008
- AUD-P2-001 a AUD-P2-010
- 11. Registro de incertidumbres
- Confirmado
- Probable
- No verificado
- Información faltante
- Bloqueadores externos
- Registro de comandos ejecutados
- Addendum - triage de revisores independientes asíncronos
- Hallazgos adicionales aceptados
- Hallazgos de subagentes re-clasificados o no aceptados
- Backlog adicional derivado del addendum
- Cierre

Instrucciones ejecutivas para el constructor

Veredicto operativo corto

CONTINUAR SOLO EN ÁREAS NO AFECTADAS.

No es necesario reiniciar Fluvia ni descartar la base actual. Sí debe congelarse temporalmente la construcción de API pública de pagos, checkout, proveedor real/mock asíncrono, webhooks externos, conciliación y modo live hasta cerrar los bloqueantes de ledger, idempotencia, outbox/inbox, autenticación de alto riesgo y evidencia de CI.

Qué debe seguir haciendo

- Continuar con remediaciones acotadas sobre la base existente.
- Continuar trabajo interno en ledger, outbox relay, inbox durable, taxonomía de errores y

observabilidad mínima.

- Mantener el stack actual: TypeScript, Fastify, Zod, PostgreSQL, pnpm workspaces/Turborepo. No hay evidencia suficiente para cambiarlo.
- Mantener el enfoque de Postgres como fuente de verdad, RLS, ledger interno y outbox transaccional.

Qué debe dejar de hacer temporalmente

- No construir todavía endpoints públicos de payment_intents, confirmación/captura/cancelación/refunds ni checkout.
- No integrar proveedor real ni declarar sandbox externo funcional.
- No emitir ni permitir uso real de API keys live fuera de gates explícitos.
- No depender de eventos outbox como entregados: hoy solo se insertan, no hay relay.
- No afirmar que tests/CI están verificados para este commit sin aportar el run verde.

Qué corregir primero

1. Invariante de base de datos: ledger_entries debe forzar que account_id pertenezca al mismo tenant y moneda.
2. Idempotencia del ledger: el replay debe comparar también reason, source y reverseTxId.
3. Evidencia reproducible: CI verde del commit auditado o autorización para pnpm install --frozen-lockfile + tests contra PostgreSQL real.
4. Outbox relay real con SKIP LOCKED, retries, backoff, DLQ y prueba con dos workers.
5. Inbox/provider events con raw body, firma, deduplicación y replay protection.
6. Rate limiting y MFA/step-up para rutas de autenticación y acciones sensibles.

Qué conservar

- Money con bigint y validación de moneda.
- Monolito modular TypeScript con SQL explícito en núcleo financiero.
- RLS con set_config(..., true) dentro de transacciones.
- Separación de roles app, auth, worker, aunque el rol worker debe reducirse.
- Audit log append-only y redacción de claves sensibles, reforzándolo con whitelists por evento.
- Chart of Accounts ejecutable y reglas tipadas de posting, con correcciones indicadas.

Qué no reescribir todavía

- No reescribir todo el ledger: la base es útil y tiene decisiones correctas.
- No sustituir Fastify/Zod por NestJS sin una razón humana/operativa fuerte.
- No externalizar el ledger a Fomance/Hyperswitch ahora: el repositorio aún se beneficia de transaccionalidad misma-BD.
- No eliminar RLS ni bajar garantías por velocidad de desarrollo.

Qué no construir todavía

- API financiera pública.
- Checkout.
- Provider adapter real.
- Webhooks salientes a comercios.
- Reconciliación operativa.
- Payouts/settlements reales.
- Production/live mode.

Qué verificar antes del siguiente incremento

- Run de CI verde para a665b4f... o ejecución local reproducible autorizada.
- Migraciones aplican dos veces: primera aplica, segunda no-op.
- Suite de invariantes ledger con casos SQL crudo adicionales.

- pnpm audit --audit-level high sigue verde; en esta auditoría sí devolvió "No known vulnerabilities found".
- Secret scanning histórico con gitleaks en GitHub Actions.

Hallazgos bloqueantes

- AUD-P1-001: invariante DB incompleta en ledger_entries.
- AUD-P1-002: payments core documentado pero no implementado.
- AUD-P1-003: idempotencia API pública no implementada.
- AUD-P1-004: outbox sin relay.
- AUD-P1-005: inbox/webhooks entrantes no implementados.
- AUD-P1-006: falta rate limiting y MFA/step-up para acciones sensibles.
- AUD-P1-007: fluvia_worker tiene BYPASSRLS y privilegios demasiado amplios.
- AUD-P1-008: tests/build/migraciones no fueron reproducibles en el entorno de auditoría sin instalar dependencias; falta evidencia CI verde del commit.

1. Veredicto ejecutivo

Veredicto final

CONTINUAR SOLO EN ÁREAS NO AFECTADAS.

Razón

La base actual no es un cascarón vacío: hay implementación real de identidad, autenticación básica, RBAC, API keys, audit log, migraciones RLS, Money, ledger service, chart of accounts y reglas de posting. También hay documentación arquitectónica extensa y razonablemente coherente con una estrategia de pagos de alta integridad.

Sin embargo, el repositorio no está listo para seguir construyendo pagos públicos encima porque faltan controles y componentes críticos: idempotencia API, outbox relay, inbox durable, provider/webhook verification, payment attempts/FSM real, conciliación, observabilidad, restore y evidencia ejecutada de CI/tests para esta línea base. Además, el ledger necesita una corrección de integridad a nivel de motor antes de recibir nuevas funciones financieras.

Áreas que pueden continuar

- Correcciones de ledger y pruebas de invariantes.
- Outbox relay e inbox durable.
- Taxonomía de errores.
- Observabilidad básica.
- Hardening de auth, rate limiting y MFA/step-up.
- Actualización documental de estado real.

Áreas que deben pausarse

- Payment API pública.
- Checkout.
- MockProvider asíncrono si pretende simular realidad de proveedor.
- Provider real.
- Webhooks externos a comercios.
- Conciliación operativa.
- Producción, sandbox compartido o modo live.

2. Estado real

Funcional y verificado en esta auditoría

- Repositorio clonado y estado Git limpio. Evidencia: `git status --short --branch` devolvió `## claude/new-session-haeo7h...origin/claude/new-session-haeo7h`.
- Línea base identificada: `commit a665b4ff6a8dca5e64e786b534ce1f2da85455f2`, fecha `2026-07-04T17:57:39Z`.
- `pnpm audit --audit-level high` ejecutado en el árbol clonado devolvió `No known vulnerabilities found`.
- Búsqueda focalizada de secretos no encontró claves reales obvias; solo credenciales de desarrollo/documentación (`postgres`, `fluvia__dev_password`, `placeholders`).
- Estructura monorepo TypeScript verificada por archivos y manifests.

Funcional parcialmente, verificado por inspección estática pero no por ejecución completa

- `packages/money`: value object con `bigint`, validación de monedas y operaciones de reparto.
- `packages/config`: configuración tipada con defaults solo `local/test` y `fail-fast` fuera de esos entornos.
- `packages/db`: migrator, pools y `withTenantTransaction` con `SET LOCAL`.
- `packages/identity`: `organizations/users/memberships/merchants`, RBAC y API keys.
- `packages/auth`: registro, verificación email, login, logout, sesiones.
- `packages/audit`: audit log append-only, redacción y operación de plataforma auditada.
- `packages/ledger`: `LedgerService`, chart of accounts, posting rules, outbox insert.
- `apps/api`: `health/ready`, auth routes, organizations, merchants, API keys, audit events, `/v1/account`.

No se ejecutaron tests completos porque el entorno clonado no tenía dependencias utilizables (eslint y vitest no encontrados) y no se instaló nada por restricción de auditoría.

Simulado

- `PostingService.releaseSettlement`, `requestRefund`, `settleRefund`: reglas contables de sandbox, no integración real con proveedor.
- `Fees/settlement/refund` son modelos contables internos, no operación bancaria ni proveedor real.

Placeholder

- `apps/worker`: solo readiness, heartbeat y shutdown; no procesa outbox/inbox/webhooks.
- `payment_intents`: tabla mínima heredada/fundacional sin servicio/FSM/API real.
- `raw_provider_payloads_dlq`: tabla existe, pero no hay pipeline que la use.

Documentado pero no implementado

- Payment Attempt, Authorization/Capture, Refund FSM de dominio.
- API `/v1/payment_intents`.
- Idempotencia API pública sobre `idempotency_keys`.
- Outbox relay.
- Inbox/provider events.
- Webhooks salientes con firma, SSRF guard, rotación y reenvíos.
- Reconciliación, casos operativos, settlements/payouts reales.
- Observabilidad con OTel, métricas, dashboards y alertas.

- Backup/restore drills.
- MFA TOTP y step-up.
- KYC/KYB/AML/sanciones/revisión legal.

Implementado pero no probado por esta auditoría

- Todas las suites reportadas en docs/agents/STATE.md como 162/162 quedan no verificadas localmente.
- Migraciones no fueron ejecutadas en esta auditoría porque Docker/psql no estaban disponibles y no se aplicaron cambios de entorno.
- CI GitHub no fue consultado/validado con un run verde asociado al commit auditado.

Fallido

- pnpm lint falló: eslint: not found.
- pnpm --filter @fluvia/config run test falló: vitest: not found.
- Docker no disponible: docker: command not found.
- psql no disponible: psql: command not found.

Bloqueado

- Ejecución local completa de pnpm lint, pnpm build, pnpm test, pnpm migrate contra PostgreSQL real.
- Verificación de RLS/ledger en motor real dentro de esta auditoría.

No evaluable

- Infra cloud, secrets manager, backups reales, deploy, alertas, dashboards.
- Legal/compliance para Colombia, KYC/KYB, AML, sanciones, PCI operativo.
- Historial Git completo con gitleaks; está configurado en CI, pero no verificado aquí.

3. Inventario técnico

Aplicaciones

Aplicación | Estado | Evidencia
 apps/api | Implementada parcialmente | apps/api/src/app.ts, routes/auth.ts, routes/organizations.ts, security.ts
 apps/worker | Placeholder operativo | apps/worker/src/worker.ts:15-20 indica que consumidores reales se registrarán después

Paquetes

Paquete | Responsabilidad | Estado
 @fluvia/config | Config Zod, entornos | Parcialmente correcto
 @fluvia/db | Pool, migrator, testing, migrations | Parcialmente correcto; requiere verificación runtime
 @fluvia/money | Money V0 bigint | Correcto por inspección; tests no ejecutados
 @fluvia/identity | Tenancy, merchants, RBAC, API keys | Parcialmente correcto
 @fluvia/auth | Auth, sesiones, logout | Parcial; falta rate limit/MFA
 @fluvia/audit | Audit append-only | Parcial; reforzar redacción
 @fluvia/ledger | Ledger service, CoA, postings | Base sólida; requiere correcciones P1/P2

Servicios y bases de datos

- PostgreSQL 16 esperado como fuente de verdad.
- Redis 7 reservado, aún sin uso crítico.
- No hay proveedor real ni mock provider implementado como servicio.
- No hay motor de webhooks salientes.
- No hay motor de conciliación.

Infraestructura

- docker-compose.yml: Postgres + Redis local.
- .github/workflows/ci.yml: CI declarada con lint, format, build, migrations, tests, gitleaks, audit y SBOM.
- No se observó Dockerfile de API/worker, laC, deployment manifests ni runbooks ejecutables.

Dependencias directas externas

Consulta al registry npm para dependencias directas externas: MIT para fastify, pg, pino, zod, vitest, eslint, prettier, turbo, tsx, typescript-eslint, @types/*; Apache-2.0 para typescript. No se verificó license tree transitivo completo.

4. Hallazgos priorizados

No se identificó un P0 que obligue a detener todo el desarrollo. Sí hay P1 que bloquean construir pagos públicos, proveedor, webhooks y live mode.

P1 - Alto / bloqueante por área

AUD-P1-001 - ledger_entries no fuerza en DB que la cuenta pertenezca al mismo tenant y moneda

- Severidad: P1.
- Área: Ledger / Base de datos / Integridad financiera.
- Decisión de continuidad: BLOQUEANTE para nuevas mutaciones financieras o scripts/admin sobre ledger.
- Descripción: ledger_entries tiene tenant_id, account_id y currency, pero la DB solo referencia ledger_accounts(id). No hay FK/constraint compuesta que garantice que la cuenta sea del mismo tenant ni que la moneda del asiento coincida con la cuenta.
- Evidencia: packages/db/migrations/0001_foundation.sql:72-84; ledger_accounts en 0001_foundation.sql:39-55; validación solo en servicio packages/ledger/src/service.ts:180-198; trigger de balance por entry currency en 0007_ledger_core.sql:81-109.
- Impacto: corrupción contable posible vía SQL crudo/admin/helper futuro aunque el asiento balancee globalmente por ledger_entries.currency.
- Probabilidad: Media durante desarrollo y soporte; baja vía servicio actual si se usa correctamente.
- Escenario de falla: un script inserta tenant_id=A con account_id de tenant B o cuenta COP con entry USD. La transacción puede balancear y commitear, rompiendo reconstrucción y conciliación.
- Causa raíz: garantía semántica delegada al servicio, no al motor.
- Recomendación: añadir constraint/FK compuesta (account_id, tenant_id, currency) o trigger diferido que valide cuenta, tenant y moneda. Añadir pruebas SQL crudo incluso como admin.
- Alternativas: script externo de invariantes como detector posterior; no suficiente como única defensa.
- Esfuerzo relativo: S/M.

- Dependencias: migración con validación de datos existentes.
- Criterio de aceptación: ningún cliente puede commitear entry con cuenta de otro tenant o moneda incorrecta.
- Prueba requerida: tests negativos en ledger-invariants.test.ts con SQL manual.

AUD-P1-002 - Payments core documentado pero no implementado

- Severidad: P1.
- Área: Payments core / Producto.
- Decisión de continuidad: BLOQUEANTE para checkout, provider y refunds públicos.
- Descripción: existe una tabla mínima payment_intents, pero no hay servicio, rutas, FSM ejecutable, payment attempts, provider adapter ni API de pagos.
- Evidencia: packages/db/migrations/0001_foundation.sql:127-149; apps/api/src/routes solo contiene auth/organizations; backlog ubica payments en F3 (docs/agents/BACKLOG.md:41).
- Impacto: no puede declararse autorización, captura, cancelación, refunds ni manejo de estados asíncronos.
- Probabilidad: Alta de confusión por documentación amplia.
- Escenario de falla: construir checkout sobre tabla mínima sin FSM ni idempotencia, permitiendo estados inválidos.
- Causa raíz: diseño documentado antes de implementación de dominio.
- Recomendación: implementar FSM declarativa y servicios de transición antes de cualquier endpoint público.
- Alternativas: renombrar/marcar tabla como placeholder hasta F3.
- Esfuerzo: L.
- Dependencias: idempotencia API, ledger corregido, inbox/outbox.
- Criterio de aceptación: matriz de transiciones cubierta por tests; endpoints mutantes idempotentes; intent/attempt separados.
- Prueba requerida: tests de FSM, concurrencia confirm/cancel, eventos tardíos/fuera de orden.

AUD-P1-003 - Idempotencia API pública no implementada

- Severidad: P1.
- Área: Idempotencia / API financiera.
- Decisión de continuidad: BLOQUEANTE para endpoints financieros mutantes.
- Descripción: tabla idempotency_keys existe, pero no hay middleware/servicio que la use en API.
- Evidencia: 0001_foundation.sql:113-125; no hay uso en apps/api/src; backlog F2-09/F2-10 pendiente en docs/agents/BACKLOG.md:34-35.
- Impacto: retries HTTP pueden duplicar objetos o respuestas.
- Probabilidad: Alta si se expone API antes de F2-09.
- Escenario de falla: cliente reintenta creación/confirmación tras timeout y se duplican intentos o capturas.
- Causa raíz: tabla fundacional sin capa de aplicación.
- Recomendación: implementar contrato Idempotency-Key antes de pagos/refunds.
- Alternativas: no exponer mutaciones públicas hasta implementarlo.
- Esfuerzo: M.
- Dependencias: taxonomía de errores F1-08.
- Criterio de aceptación: mismo key+payload devuelve mismo resultado; payload distinto rechaza; carrera N->1.
- Prueba requerida: concurrencia y crash pre/post commit.

AUD-P1-004 - Outbox sin relay

- Severidad: P1.
- Área: Procesamiento asíncrono.
- Decisión de continuidad: INCORPORAR INMEDIATAMENTE si el siguiente trabajo depende de eventos.
- Descripción: el ledger escribe eventos al outbox, pero el worker no los procesa.

- Evidencia: outbox_events en 0001_foundation.sql:95-110; inserción en packages/ledger/src/service.ts:226-237; worker placeholder en apps/worker/src/worker.ts:15-20; F2-11 pendiente.
- Impacto: eventos no salen ni se reintentan; downstream no funciona.
- Probabilidad: Actual.
- Escenario de falla: posting exitoso queda pending indefinidamente.
- Causa raíz: patrón persistido antes de relay.
- Recomendación: implementar relay con FOR UPDATE SKIP LOCKED, retries, backoff+jitter, DLQ, métricas y replay auditado.
- Alternativas: tratar outbox como evidencia local, no delivery.
- Esfuerzo: M.
- Dependencias: reducción de privilegios worker.
- Criterio de aceptación: dos workers no duplican entrega; poison event termina dead; crash no pierde evento.
- Prueba requerida: integración con dos workers y fallos inyectados.

AUD-P1-005 - Inbox/provider events y webhook verification no implementados

- Severidad: P1.
- Área: Webhooks entrantes / Provider events.
- Decisión de continuidad: BLOQUEANTE para provider/mock asíncrono.
- Descripción: no hay provider_events, raw body verification, firma, replay protection ni dedupe.
- Evidencia: solo raw_provider_payloads_dlq en 0001_foundation.sql:151-162; F2-12 pendiente en docs/agents/BACKLOG.md:37; búsquedas de código no encontraron verificación webhook.
- Impacto: no se pueden manejar duplicados, eventos fuera de orden ni payloads inválidos de forma durable.
- Probabilidad: Alta al integrar proveedor.
- Escenario de falla: provider envía evento duplicado y se procesa dos veces o se pierde.
- Causa raíz: diseño diferido.
- Recomendación: implementar inbox durable antes de MockProvider realista.
- Alternativas: mock síncrono solo para tests unitarios, declarado como no representativo.
- Esfuerzo: M.
- Dependencias: outbox relay y FSM de pagos.
- Criterio de aceptación: duplicados -> un procesamiento; firma inválida rechazada; payload inválido -> DLQ; raw body persistido.
- Prueba requerida: tests de firma, dedupe, eventos tardíos/fuera de orden.

AUD-P1-006 - Falta rate limiting y MFA/step-up para acciones sensibles

- Severidad: P1.
- Área: Seguridad / Auth.
- Decisión de continuidad: BLOQUEANTE para exponer dashboard/API keys a usuarios reales.
- Descripción: login/register/verify no tienen rate limiting. MFA/step-up está pendiente aunque existen endpoints de API key management.
- Evidencia: rutas auth en apps/api/src/routes/auth.ts:22-50; script costoso en packages/auth/src/passwords.ts:17-30; endpoints de keys en apps/api/src/routes/organizations.ts:132-177; pendiente en docs/agents/STATE.md:11 y BACKLOG.md:14.
- Impacto: DoS por hashing, abuso de registro, creación de API keys con sesión robada.
- Probabilidad: Alta al exponer API.
- Escenario de falla: botnet fuerza login con emails inexistentes; sesión robada crea API key.
- Causa raíz: auth base implementada antes de rate limits y step-up.
- Recomendación: rate limit por IP/email/ruta; MFA TOTP y step-up para keys:manage y futuras acciones financieras.
- Alternativas: feature flag para deshabilitar endpoints sensibles fuera de local/test.
- Esfuerzo: M/L.

- Dependencias: observabilidad y store de rate limit.
- Criterio de aceptación: excedentes devuelven error estable; step-up requerido y auditado.
- Prueba requerida: tests de throttle y step-up expiry.

AUD-P1-007 - fluvia_worker tiene BYPASSRLS y privilegios demasiado amplios

- Severidad: P1.
- Área: Multi-tenancy / Least privilege.
- Decisión de continuidad: BLOQUEANTE antes de desplegar worker real.
- Descripción: el rol worker puede bypass RLS y recibe SELECT, INSERT, UPDATE sobre todas las tablas, aunque hoy el worker solo heartbeat.
- Evidencia: packages/db/migrations/0002_enable_rls.sql:22-33; worker placeholder apps/worker/src/worker.ts:15-20.
- Impacto: compromiso del worker puede leer/actualizar datos cross-tenant.
- Probabilidad: Media al introducir consumidores.
- Escenario de falla: RCE en worker futuro modifica payment_intents, api_keys, outbox payloads o proyecciones.
- Causa raíz: privilegio anticipado amplio para simplificar colas.
- Recomendación: roles separados y mínimos (outbox_relay, inbox_consumer) o funciones SECURITY DEFINER acotadas.
- Alternativas: mantener BYPASSRLS solo detrás de funciones de cola con grants mínimos.
- Esfuerzo: M.
- Dependencias: F2-11/F2-12.
- Criterio de aceptación: meta-tests demuestran que worker no puede leer/actualizar tablas no necesarias.
- Prueba requerida: information_schema.role_table_grants + pruebas de denial.

AUD-P1-008 - Evidencia de CI/tests no reproducida para el commit auditado

- Severidad: P1.
- Área: Calidad / Supply chain / Evidencia.
- Decisión de continuidad: BLOQUEANTE para declarar "verificado", no para corregir.
- Descripción: el repositorio declara CI y STATE.md afirma tests verdes, pero esta auditoría no pudo ejecutarlos sin instalar dependencias; tampoco se adjuntó run de CI.
- Evidencia: pnpm lint -> eslint: not found; test config -> vitest: not found; docker y psql ausentes; CI declarada en .github/workflows/ci.yml:44-66; STATE.md:61 pide confirmar workflow verde.
- Impacto: afirmaciones de suite verde quedan no verificadas.
- Probabilidad: Alta en entorno fresco.
- Escenario de falla: se continúa sobre una suite que falla al instalarse o migrar.
- Causa raíz: baseline entregada sin artefacto de CI ni autorización de instalación.
- Recomendación: adjuntar run verde del commit o autorizar instalación temporal reproducible.
- Alternativas: usar GitHub Actions como evidencia oficial.
- Esfuerzo: XS.
- Criterio de aceptación: logs de pnpm install --frozen-lockfile, lint, build, migrate, test, gitleaks, audit, SBOM.
- Prueba requerida: CI verde asociado a a665b4f....

P2 - Medio / siguiente ciclo

AUD-P2-001 - Replay idempotente de ledger no compara metadata causal completa

- Área: Ledger.
- Decisión: INCORPORAR INMEDIATAMENTE antes de más dominios sobre ledger.
- Evidencia: packages/ledger/src/service.ts:291-337 compara solo entries; no compara reason, source_type/source_id, reverses_tx_id.
- Impacto: mismo key + mismos asientos + source distinto replaya silenciosamente, dañando

trazabilidad.

- Recomendación: persistir/comparar payload canónico completo o comparar metadata existente.
- Criterio de aceptación: key igual con source/reason distinto lanza IdempotencyConflictError.
- Prueba: test en ledger-service.test.ts.

AUD-P2-002 - payment_intents mínima puede quedar obsoleta frente al FSM documentado

- Área: DB / Payments.
- Decisión: INCORPORAR INMEDIATAMENTE antes de API PaymentIntent.
- Evidencia: 0001_foundation.sql:132-147; diseño más amplio en docs/architecture/payment-state-machines.md.
- Impacto: migraciones correctivas o estados insuficientes.
- Recomendación: revisar schema contra FSM final antes de construir servicios.
- Prueba: schema-vs-FSM contract test.

AUD-P2-003 - API keys live existen sin frontera operacional real

- Área: Seguridad / Entornos.
- Decisión: INCORPORAR INMEDIATAMENTE antes de endpoints financieros.
- Evidencia: packages/identity/src/api-keys.ts:25-35,104; security.ts:75-96 autentica environment pero no impone gating.
- Impacto: falsa sensación de producción/live.
- Recomendación: bloquear creación/uso de live fuera de entorno aprobado y gates humanos.
- Prueba: tests create/use live en local/test/sandbox deben rechazar.

AUD-P2-004 - balance_projections permite UPDATE directo por rol app/worker

- Área: Ledger / Proyecciones.
- Decisión: INCORPORAR EN LA SIGUIENTE FASE.
- Evidencia: grants globales 0002_enable_rls.sql:30-33; 0007 no prohíbe UPDATE; servicio actual actualiza con guard en service.ts:276-288.
- Impacto: drift posible por bug interno.
- Recomendación: limitar UPDATE o implementar drift checker F2-05 inmediatamente.
- Prueba: intento de update directo falla o drift checker lo detecta.

AUD-P2-005 - Outbox payload carece de envelope/constraints mínimos

- Área: Eventos.
- Decisión: INCORPORAR INMEDIATAMENTE con F2-11.
- Evidencia: outbox_events.payload JSONB en 0001_foundation.sql:95-106; ledger incluye schema_version solo por convención en service.ts:229-236.
- Impacto: producers futuros pueden romper consumers.
- Recomendación: helper/envelope común con event_id, schema_version, occurred_at, producer, resource.
- Prueba: contract tests de event envelope.

AUD-P2-006 - Reconciliación no implementada

- Área: Reconciliación.
- Decisión: INCORPORAR EN LA SIGUIENTE FASE antes de proveedor real.
- Evidencia: diseño en docs/architecture/reconciliation.md; backlog F4 pendiente; no hay runtime.
- Impacto: no hay detección/resolución de discrepancias.
- Recomendación: empezar con MockProvider reports con discrepancias inyectables.
- Prueba: archivo simulado genera casos con evidencia.

AUD-P2-007 - Observabilidad, backups/restore y runbooks no implementados

- Área: Operaciones.
- Decisión: INCORPORAR EN LA SIGUIENTE FASE; bloquea producción/proveedor real.
- Evidencia: F1-07 pendiente docs/agents/BACKLOG.md:17; Gate Restore rojo docs/compliance/production-gates.md:39-40.
- Impacto: incidentes no diagnosticables ni recuperables con evidencia.
- Recomendación: OTel/métricas/logs, dashboards, restore drill con ledger verification.
- Prueba: drill restore reproducible.

AUD-P2-008 - Migraciones crean roles con passwords de desarrollo

- Área: Config / Seguridad operacional.
- Decisión: INCORPORAR EN LA SIGUIENTE FASE antes de sandbox/staging.
- Evidencia: 0002_enable_rls.sql:20,23; 0004_auth_sessions.sql:78-80.
- Impacto: credenciales conocidas si se corre tal cual fuera de local.
- Recomendación: separar provisioning de roles o fallar fuera de local si roles no existen.
- Prueba: dry-run en entorno no local con roles precreados.

AUD-P2-009 - Taxonomía final de errores pendiente; mensajes de dominio pueden filtrar detalles

- Área: API / Seguridad.
- Decisión: INCORPORAR INMEDIATAMENTE antes de API pública financiera.
- Evidencia: apps/api/src/app.ts:135-140 devuelve err.message; F1-08 pendiente.
- Impacto: futuros errores pueden filtrar IDs internos o estados.
- Recomendación: catálogo público de códigos/mensajes y details whitelisted.
- Prueba: contract tests que no exponen UUIDs/secrets/SQL.

AUD-P2-010 - Licencias transitivas/SBOM no materializadas en la línea base

- Área: Supply chain / Legal.
- Decisión: INCORPORAR EN LA SIGUIENTE FASE antes de release externa.
- Evidencia: CI genera SBOM .github/workflows/ci.yml:94-99, pero no hay artefacto adjunto; F0-VER pendiente BACKLOG.md:9.
- Impacto: riesgo legal no cerrado.
- Recomendación: SBOM + license report por commit.
- Prueba: artefacto SPDX y resumen de licencias.

P3 - Bajo / mejoras recomendables

AUD-P3-001 - README desactualizado respecto a STATE

- Área: Documentación.
- Decisión: INCORPORAR INMEDIATAMENTE por coordinación, aunque técnicamente bajo.
- Evidencia: README.md:5 dice Fase 0; docs/agents/STATE.md:3 dice Fase 2.
- Recomendación: separar "pre-producción" de "fase actual".
- Prueba: revisión documental.

AUD-P3-002 - Documentos de diseño no indican siempre estado de implementación

- Área: Documentación / Multi-agente.
- Decisión: OPCIONAL.
- Evidencia: docs cubren webhooks/reconciliation/payment lifecycle aunque runtime no existe.
- Recomendación: bloque "Estado de implementación" en cada doc.

AUD-P3-003 - No hay Dockerfile/app compose completo

- Área: DX / Infra local.
- Decisión: INCORPORAR EN SIGUIENTE FASE antes del objetivo DX del MVP.

- Evidencia: docker-compose.yml solo Postgres/Redis.
- Recomendación: compose completo/devcontainer cuando exista E2E sandbox.

5. Matriz requisito contra implementación

Requisito importante | Estado | Evidencia | Brecha | Recomendación

Monolito modular TypeScript | Implementado | pnpm-workspace.yaml, packages/, apps/ | No runtime verificado | Mantener

Postgres fuente de verdad | Implementado parcialmente | docker-compose.yml, migrations | No restore/backup | Mantener y añadir restore drills

Money sin floats | Implementado | packages/money/src/money.ts | Tests no ejecutados | Mantener

RLS multi-tenant | Implementado parcialmente | 0002, 0003, withTenantTransaction | Worker bypass amplio; runtime no verificado | Mantener, reducir worker

RBAC | Implementado para endpoints actuales | rbac.ts, security.ts, org routes | Falta step-up | Mantener y extender

API keys hash + scopes | Implementado | api-keys.ts, 0005 | live sin gating | Bloquear live hasta gates

MFA/step-up | No implementado | STATE.md:11, BACKLOG.md:14 | Acciones sensibles sin 2FA | Implementar antes de usuarios reales

Audit log append-only | Implementado parcialmente | 0006, audit/src/index.ts | Redacción por regex puede ser insuficiente | Whitelist por evento

Ledger doble partida por moneda | Implementado parcialmente | 0007 triggers | Falta tenant/currency account constraint | Corregir P1

Ledger idempotente | Parcial | LedgerService | Replay no compara metadata completa | Corregir P2

PaymentIntent/Attempt FSM | Documentado, no implementado | docs, tabla mínima payment_intents | No service/API/attempts | No construir checkout hasta implementarlo

Idempotencia API | Tabla existe, no implementada | idempotency_keys; backlog F2-09 | No middleware/crash tests | Implementar antes de API financiera

Outbox | Tabla + producer | outbox_events, ledger insert | No relay | Implementar F2-11

Inbox/provider events | No implementado | solo DLQ; F2-12 pendiente | No raw body/firma/dedupe | Implementar antes de provider

Webhooks salientes | Documentado, no implementado | docs/architecture/webhook-delivery.md | No delivery/SSRF/signing | Después de outbox relay

Reconciliación | Documentado, no implementado | docs/architecture/reconciliation.md | No motor/casos | Antes de proveedor real

Observabilidad | Mínima | request-id/log redaction | No metrics/tracing/alerts | F1-07

CI/security/SBOM | Configurado, no evidenciado | .github/workflows/ci.yml | No run verde adjunto | Adjuntar evidencia

Compliance/producción | Correctamente bloqueado | production-gates.md | Gates rojos | No declarar producción

6. Análisis del prompt maestro

La auditoría no recibió el prompt maestro original completo salvo documentación derivada (docs/agents/prompt-audit-v4.md, ADRs y PRD). Por tanto, las conclusiones siguientes se basan en esa documentación y el código.

Instrucciones que deben mantenerse

- Invariantes de ledger por transacción y por activo/moneda.
- Idempotencia durable en Postgres, no dependiente de Redis.
- Outbox/inbox transaccional para eventos críticos.
- No llamadas externas dentro de transacciones SQL.
- RLS con tenant derivado de identidad autenticada, no del payload.
- No declarar producción sin gates de seguridad, restore, legal y proveedor.
- No procesar PAN/CVV dentro de Fluvia.
- Auditoría append-only para acciones sensibles.

Instrucciones demasiado rígidas

- Prohibición universal de DELETE en todas las tablas técnicas. Está bien como default temprano, pero sesiones expiradas e idempotency keys requieren purga auditada por retención. El propio backlog F1-09 lo reconoce.
- Documentar todas las piezas futuras sin marcar estado de implementación puede ser contraproducente para agentes; debe añadirse estado por doc.

Instrucciones o decisiones inconvenientes

- Crear API keys live antes de enforcement de entornos y production gates es prematuro.
- Dar BYPASSRLS y grants amplios al worker antes de existir worker real aumenta riesgo innecesario.
- Mantener tabla mínima payment_intents puede inducir a construir sobre un schema incompleto si no se revisa antes de F3.

Instrucciones faltantes

- Rate limiting obligatorio para auth y endpoints públicos.
- MFA/step-up como gate antes de acciones high-risk ya existentes.
- Constraint de motor para ledger_entries contra tenant/currency de cuenta.
- Política explícita para roles DB en sandbox/staging/prod, separada de migraciones locales.
- Evidencia obligatoria de CI verde por commit de línea base.
- Estado de implementación en docs extensas.

Decisiones que deben quedar a criterio del constructor

- Fastify/Zod vs NestJS: la elección actual está justificada; no imponer NestJS.
- Ledger interno vs servicio externo: mantener interno en MVP por transaccionalidad.
- Implementación exacta de rate limiting: Redis, gateway o ambos; lo obligatorio es el control verificable.
- PDF/SBOM/reporting tooling; lo obligatorio es evidencia reproducible.

Correcciones recomendadas al prompt/proceso

- Añadir "no crear ni aceptar live keys hasta gates live".
- Añadir "toda FK financiera debe codificar tenant y activo/moneda donde aplique".
- Añadir "cada documento de diseño debe declarar estado: implementado/parcial/no implementado".
- Añadir "run CI verde por commit es parte del handoff".

7. Riesgos

Financieros

- Ledger puede aceptar inconsistencia tenant/currency vía SQL crudo si no se corrige.
- Reconciliación ausente; no hay detección de discrepancias proveedor-ledger.
- API idempotency ausente; riesgo de duplicación cuando existan endpoints.

Técnicos

- Outbox/inbox faltantes bloquean arquitectura asíncrona.
- Worker con privilegios amplios.
- Tests no reproducidos en auditoría.

Seguridad

- Auth sin rate limit.
- MFA/step-up pendiente.
- Live API keys prematuras.
- Redacción audit por regex puede dejar escapar valores sensibles en campos genéricos.

Multi-tenant

- RLS parece bien diseñado, pero worker bypass es un punto crítico.
- Ledger entries no amarran cuenta-tenant-moneda en DB.

Operativos

- Observabilidad y restore no implementados.
- No hay runbooks ejecutables.
- No hay evidence dossier CI adjunto.

Regulatorios/compliance

- Production gates correctamente rojos.
- KYC/KYB/AML/sanciones/legal no resueltos.
- PCI scope documentado, pero no validado operativo.

Datos

- Retención/purga técnica pendiente.
- Backups/restore no probados.

Dependencias

- Direct dependencies parecen licencias permisivas, pero transitivas no cerradas con SBOM en esta línea base.

Continuidad

- README vs STATE inconsistente puede desorientar agentes y causar rework.

8. Deuda técnica

Deuda aceptable

- Worker esqueleto mientras no se dependa de eventos.
- No Dockerfile completo mientras no exista E2E sandbox.
- Reconciliación documentada para fase posterior, siempre que no se prometa.

Deuda que bloquea

- Invariante DB de ledger entries.
- Idempotencia API antes de endpoints mutantes.
- Outbox relay antes de webhooks/eventos dependientes.

- Inbox antes de proveedor asíncrono.
- Rate limiting/MFA antes de usuarios reales.
- Evidencia CI antes de declarar verificado.

Deuda que empeorará rápidamente

- Worker BYPASSRLS con grants globales.
- payment_intents mínima si se empieza a construir encima.
- Error handling con err.message en dominios sensibles.
- Docs sin estado de implementación.

Deuda que puede posponerse

- Dockerfile/devcontainer completo.
- License report transitivo hasta release externa, aunque conviene hacerlo pronto.
- UI/CSRF/CSP hasta dashboard real.

9. Plan de remediación

Acción | Prioridad | Responsable sugerido | Criterio de aceptación | Prueba | Evidencia | Talla

Añadir constraint DB tenant/currency para ledger entries | P1 | Backend/DB | SQL crudo no puede insertar entry incoherente | Tests negativos PG | logs tests + migración | S/M

Comparar metadata completa en ledger idempotency replay | P2 | Backend ledger | source/reason distinto rechaza | unit/integration | test verde | S

Adjuntar CI verde del commit o autorizar instalación reproducible | P1 | DevOps/owner | lint/build/migrate/test/security verdes | GitHub Actions/local | URL/log | XS

Actualizar README estado real | P3 | Constructor | README y STATE concuerdan | revisión | diff doc | XS

Implementar F1-08 taxonomía de errores | P2 | API | mensajes públicos no filtran internos | contract tests | tests | S

Implementar rate limiting auth/API | P1 | Security/API | abuso throttled sin enumeración | integration tests | métricas/logs | M

Implementar MFA/step-up high-risk | P1 | Security/API | keys/manage requiere factor reciente | integration tests | audit events | L

Reducir privilegios worker | P1 | DB/Worker | grants mínimos | meta-tests grants | query evidence | M

Implementar outbox relay | P1 | Worker | 2 workers sin doble entrega; DLQ | integration | logs/metrics | M

Definir envelope outbox común | P2 | Platform | todo evento cumple schema | contract tests | tests | S

Implementar inbox durable | P1 | Worker/API | firma/raw/dedupe/DLQ | integration | tests | M

Implementar idempotencia API | P1 | API | same key same response; conflict distinto | concurrency/crash | tests | M

Revisar schema PaymentIntent vs FSM | P2 | Payments | schema mapea FSM | tests | ADR/migración | S/M

Implementar FSM PaymentIntent/Attempt | P1 | Payments | transiciones válidas únicamente | FSM tests | tests | L

Implementar drift check/rebuild | P2 | Ledger/Ops | proyección reconstruible | property/integration | report | M

Implementar reversals normativos | P2 | Ledger | reversal netea original y audita | integration | tests | M

Observabilidad base | P2 | Platform/Ops | métricas/traces/logs correlacionados | smoke | dashboard | M

Backup/restore drill | P2 | Ops/DB | restore + ledger verification | drill | runbook/log | L

SBOM/license report | P2 | DevOps | SPDX + summary por commit | tool run | artifact | S

10. Próxima secuencia recomendada

Qué corregir primero

1. AUD-P1-008: obtener evidencia CI verde o reproducir localmente con autorización.
2. AUD-P1-001: cerrar invariante de ledger_entries en DB.
3. AUD-P2-001: completar huella idempotente del ledger.
4. AUD-P1-007: reducir privilegios worker antes del relay.
5. AUD-P1-004 + AUD-P2-005: outbox relay + envelope.
6. AUD-P1-005: inbox durable.
7. AUD-P1-003: idempotencia API pública.
8. AUD-P1-006: rate limiting y step-up.
9. Recién después, payments FSM/API.

Qué conservar

- Monolito modular actual.
- SQL explícito en núcleo financiero.
- RLS + SET LOCAL.
- Ledger interno y chart of accounts.
- Audit append-only.
- CI declarada, reforzando evidencia.

Qué eliminar o desactivar temporalmente

- Emisión/uso de API keys live fuera de entorno aprobado.
- Cualquier afirmación de "payment core listo" más allá de ledger/posting interno.

Qué refactorizar

- Privilegios del worker.
- Error mapping público.
- Tabla/schema de payment_intents antes de API real.
- Redacción audit hacia whitelists por evento.

Qué no construir todavía

- Checkout.
- Provider real.
- Webhooks externos.
- Reconciliación operativa.
- Payouts/settlements reales.
- Production/live mode.

Qué puede continuar en paralelo

- Actualización documental README/estado.
- SBOM/license report.
- Observabilidad base.
- Diseño detallado FSM siempre que no se exponga API.

Decisiones humanas necesarias

- Confirmar si se autoriza instalación reproducible para verificar localmente.
- Decidir política de live keys: bloquear completamente o feature flag por entorno.
- Decidir modelo MFA/step-up y recuperación de cuenta.
- Decidir cuándo aceptar sandbox compartido y qué gates mínimos exige.
- Revisión legal Colombia/KYC/KYB/AML antes de proveedor real.

Cuándo volver a auditar

- Después de cerrar AUD-P1-001, AUD-P1-003, AUD-P1-004, AUD-P1-005, AUD-P1-006, AUD-P1-007 y aportar CI verde.
- Antes de abrir API financiera pública.
- Antes de integrar proveedor real.
- Antes de declarar sandbox externo o live mode.

Plan de incorporación de hallazgos al desarrollo activo

Hallazgo | Severidad | Decisión de continuidad | Área | Acción requerida | Orden | Dependencias
 | Riesgo de no aplicarlo | CA | Prueba | Evidencia | Talla | Momento | ¿Detener trabajo actual?
 AUD-P1-008 | P1 | BLOQUEANTE para verificación | CI/tests | Adjuntar CI verde o reproducir | 1
 | red/GHA/autorización | trabajar sobre base no verificada | logs verdes | CI/local | URL/log |
 XS | Ahora | No todo; sí claims
 AUD-P1-001 | P1 | BLOQUEANTE | Ledger DB | Constraint tenant/currency | 2 | migración |
 corrupción ledger | SQL inválido falla | PG tests | test log | S/M | Ahora | Sí, ledger
 financiero
 AUD-P2-001 | P2 | INCORPORAR INMEDIATAMENTE | Ledger | Comparar metadata idempotencia | 3 |
 ninguna | trazabilidad rota | conflict correcto | integration | test log | S | Ahora | No
 AUD-P1-007 | P1 | BLOQUEANTE | Worker/RLS | Reducir grants/BYPASSRLS | 4 | diseño relay |
 escape por worker | grants mínimos | meta-tests | query evidence | M | Antes relay | Sí, worker
 real
 AUD-P1-004 | P1 | INCORPORAR INMEDIATAMENTE | Outbox | Relay con locks/retries/DLQ | 5 | worker
 role | eventos estancados | no doble entrega | 2 workers | logs | M | F2-11 | Sí si eventos
 AUD-P2-005 | P2 | INCORPORAR INMEDIATAMENTE | Eventos | Envelope común | 6 | outbox | consumers
 frágiles | schema estable | contract | tests | S | F2-11 | No
 AUD-P1-005 | P1 | BLOQUEANTE | Inbox/webhooks | Raw+firma+dedupe+DLQ | 7 | relay | eventos
 duplicados/perdidos | dedupe 1x | integration | tests | M | F2-12 | Sí, provider
 AUD-P1-003 | P1 | BLOQUEANTE | API | Idempotency middleware | 8 | errores API | duplicación
 HTTP | same key same response | concurrency/crash | tests | M | Antes payments API | Sí, API
 mutante
 AUD-P1-006 | P1 | BLOQUEANTE | Auth | Rate limit + MFA/step-up | 9 | observabilidad/store |
 DoS/escalada | throttle/step-up | integration | logs/audit | M/L | Antes usuarios reales | Sí,
 dashboard real
 AUD-P2-003 | P2 | INCORPORAR INMEDIATAMENTE | Entornos | Bloquear live keys | 10 | policy
 humana | falsa producción | live rechazado | tests | test log | S | Antes API financiera | No
 AUD-P2-009 | P2 | INCORPORAR INMEDIATAMENTE | API | Taxonomía errores | 11 | ninguna |
 leaks/SDK frágil | mensajes públicos | contract | tests | S | Antes API pública | No
 AUD-P1-002 | P1 | BLOQUEANTE | Payments | FSM + Attempts + API | 12 | ledger/idempot/inbox |
 estados inválidos | transiciones válidas | FSM tests | tests | L | Después F2 | Sí, payments
 AUD-P2-006 | P2 | SIGUIENTE FASE | Recon | Motor reconciliación | 13 | provider mock |
 discrepancias invisibles | cases/evidence | reports | tests | L/XL | Antes proveedor real | No
 ahora
 AUD-P2-007 | P2 | SIGUIENTE FASE | Ops | Observabilidad/restore | 14 | infra | incidentes
 opacos | drill OK | restore | runbook | L | Antes sandbox/prod | No ahora
 AUD-P3-001 | P3 | INCORPORAR INMEDIATAMENTE | Docs | README estado real | paralelo | ninguna |
 confusión agentes | docs coherentes | review | diff | XS | Ahora | No
 AUD-P2-010 | P2 | SIGUIENTE FASE | Supply chain | SBOM/license report | paralelo | tool/CI |
 riesgo legal | artifact | SBOM | SPDX | S | Antes release | No

Backlog de remediación

AUD-P1-001

- Prioridad: P1.
- Título: Forzar tenant/currency de ledger_entries en base de datos.
- Descripción: Añadir FK/constraint/triggers para que cada entry referencie una cuenta del mismo tenant y misma moneda.
- Evidencia: 0001_foundation.sql:72-84, service.ts:180-198.

- Archivos/módulos afectados: packages/db/migrations, packages/db/test/ledger-invariants.test.ts.
- Dependencias: migración segura.
- Criterios de aceptación: SQL crudo no puede violar tenant/currency.
- Pruebas requeridas: test superuser/admin cross-tenant y currency mismatch.
- Evidencia de cierre: logs de test + migración.
- Talla: S/M.
- Continuidad: BLOQUEANTE.

AUD-P1-002

- Prioridad: P1.
- Título: Implementar PaymentIntent/Attempt FSM antes de API pública.
- Descripción: Reconciliar schema con diseño y crear servicios/rutas de dominio solo después de idempotencia API.
- Evidencia: 0001_foundation.sql:127-149, docs/architecture/payment-state-machines.md.
- Archivos: nuevas migraciones, apps/api, paquete payments.
- Dependencias: AUD-P1-001, AUD-P1-003, AUD-P1-005.
- CA: transiciones inválidas imposibles; attempts separados.
- Pruebas: FSM, concurrencia, out-of-order.
- Talla: L.
- Continuidad: BLOQUEANTE.

AUD-P1-003

- Prioridad: P1.
- Título: Implementar idempotencia API pública.
- Descripción: Middleware/servicio sobre idempotency_keys para endpoints mutantes.
- Evidencia: tabla existe pero sin uso en apps/api.
- Archivos: apps/api, packages/db, tests.
- Dependencias: F1-08 errores.
- CA: same key+payload replay; payload distinto conflict.
- Pruebas: carrera N->1, crash pre/post commit.
- Talla: M.
- Continuidad: BLOQUEANTE.

AUD-P1-004

- Prioridad: P1.
- Título: Implementar outbox relay worker.
- Descripción: Procesar eventos pendientes con locks, retries, backoff, DLQ y métricas.
- Evidencia: outbox insert existe; worker placeholder.
- Archivos: apps/worker, migraciones si hacen falta.
- Dependencias: AUD-P1-007.
- CA: dos workers no duplican; poison -> dead.
- Pruebas: integración multi-worker.
- Talla: M.
- Continuidad: INCORPORAR INMEDIATAMENTE.

AUD-P1-005

- Prioridad: P1.
- Título: Implementar inbox durable y verificación de webhooks entrantes.
- Descripción: Raw body, firma, replay protection, dedupe, DLQ.
- Evidencia: solo DLQ genérica existe.

- Dependencias: outbox/worker, payments FSM.
- CA: duplicado procesa una vez; firma inválida rechaza.
- Pruebas: firma, timestamp, payload inválido, out-of-order.
- Talla: M.
- Continuidad: BLOQUEANTE.

AUD-P1-006

- Prioridad: P1.
- Título: Rate limiting + MFA/step-up.
- Descripción: Proteger auth y acciones high-risk.
- Evidencia: rutas auth sin limiter; endpoints keys sin step-up.
- Dependencias: store/observabilidad.
- CA: límites uniformes y step-up auditado.
- Pruebas: throttle, step-up expiry.
- Talla: M/L.
- Continuidad: BLOQUEANTE.

AUD-P1-007

- Prioridad: P1.
- Título: Reducir privilegios del worker.
- Descripción: Sustituir grants globales/BYPASSRLS por roles/funciones acotadas.
- Evidencia: 0002_enable_rls.sql:22-33.
- Dependencias: diseño relay/inbox.
- CA: worker no puede tocar tablas de dominio no necesarias.
- Pruebas: meta-tests grants y denial.
- Talla: M.
- Continuidad: BLOQUEANTE.

AUD-P1-008

- Prioridad: P1.
- Título: Aportar evidencia reproducible de CI/tests.
- Descripción: Run verde del commit o ejecución local autorizada.
- Evidencia: comandos fallaron por deps ausentes.
- Dependencias: CI/red/autorización.
- CA: logs verdes para lint/build/migrate/test/security.
- Pruebas: GitHub Actions o local.
- Talla: XS.
- Continuidad: BLOQUEANTE para claims de verificación.

AUD-P2-001 a AUD-P2-010

Para P2, incorporar según el plan de remediación: idempotency metadata, schema PaymentIntent, live gating, proyecciones, envelope outbox, reconciliación, observabilidad/restore, roles prod, errores API, SBOM/license report.

11. Registro de incertidumbres

Confirmado

- Branch detectada: claude/new-session-haeo7h.
- Commit detectado: a665b4ff6a8dca5e64e786b534ce1f2da85455f2.
- Estado Git limpio tras la auditoría.
- pnpm audit --audit-level high sin vulnerabilidades conocidas.
- Docker y psql no disponibles en entorno de auditoría.
- eslint y vitest no disponibles porque dependencias no estaban instaladas de forma utilizable.
- Worker no procesa outbox/inbox.
- Payments API no existe.
- CI está configurado en YAML, pero run verde no adjunto.

Probable

- Las decisiones de stack son razonables para el estado actual.
- La suite puede estar verde si se instalan dependencias y PostgreSQL real, pero no está demostrado en esta auditoría.
- RLS está bien planteado para rutas app normales, pero requiere verificación runtime y reducción worker.

No verificado

- Resultado real de pnpm test completo.
- Migraciones aplicadas en PostgreSQL 16.
- Gitleaks histórico.
- SBOM real.
- Coverage real.
- Performance/concurrencia bajo carga.
- Restore desde backup.

Información faltante

- Rama/tag/SHA exactos entregados por humano; fueron placeholders y se infirió HEAD.
- URL del run de GitHub Actions para el commit.
- Infraestructura cloud y secrets manager.
- Decisiones humanas de live mode, MFA y sandbox compartido.
- Revisión legal Colombia/KYC/KYB/AML/PCI.

Bloqueadores externos

- Autorización para instalar dependencias y ejecutar suite completa localmente.
- Disponibilidad de Docker/PostgreSQL o acceso a CI.
- Evidencia de GitHub Actions y artefactos SBOM.

Registro de comandos ejecutados

```
Comando | Resultado
git clone https://github.com/celestinojbm/Fluvia.git repo | OK
git branch --show-current | claude/new-session-haeo7h
git rev-parse HEAD | a665b4ff6a8dca5e64e786b534ce1f2da85455f2
git show -s --format=%CI HEAD | 2026-07-04T17:57:39Z
git status --short --branch | limpio
node --version | v22.23.0
pnpm --version | 10.33.0
docker --version | docker: command not found
psql --version | psql: command not found
pnpm lint | falló: eslint: not found
```

```
pnpm --filter @fluvia/config run test | falló: vitest: not found
pnpm audit --audit-level high | No known vulnerabilities found
búsqueda secretos | sin secretos reales obvios; solo dev/placeholders
consulta registry npm dependencias directas | licencias directas MIT/Apache-2.0
```

Addendum - triage de revisores independientes asíncronos

Después de generar el informe inicial, llegaron tres informes independientes de subagentes. Este addendum incorpora los hallazgos válidos y re-clasifica los que estaban sobredimensionados. No se aceptan conclusiones por autoridad del subagente: cada punto se evalúa contra evidencia del repositorio y fase real del proyecto.

Hallazgos adicionales aceptados

AUD-P1-009 - idempotency_keys no incluye endpoint en la clave primaria

- Severidad: P1.
- Área: Idempotencia API / Base de datos.
- Decisión de continuidad: BLOQUEANTE antes de implementar idempotencia HTTP.
- Descripción: La tabla idempotency_keys usa PRIMARY KEY (tenant_id, key), mientras la documentación de contrato de idempotencia requiere aislamiento por endpoint. Esto puede producir conflictos falsos entre endpoints distintos que reutilicen una misma key de cliente.
- Evidencia: packages/db/migrations/0001_foundation.sql:115-125; docs/architecture/idempotency.md describe la capa API para endpoints mutantes y, según revisión independiente, especifica (tenant_id, endpoint, key).
- Impacto: retries legítimos en endpoints distintos podrían bloquearse entre sí; o el constructor tendría que codificar endpoint dentro de la key, acoplando clientes a un detalle interno.
- Probabilidad: Alta si se implementa F2-09 sobre la tabla actual.
- Escenario de falla: un frontend reutiliza Idempotency-Key: abc para crear un checkout y luego un refund; el segundo endpoint colisiona con el primero.
- Causa raíz: tabla fundacional inerte quedó por debajo del contrato documentado.
- Recomendación: añadir columna endpoint TEXT NOT NULL y migrar la PK a (tenant_id, endpoint, key) antes de activar middleware.
- Alternativas: namespacing forzado de keys por endpoint, menos claro y más propenso a error.
- Esfuerzo: S.
- Criterio de aceptación: dos endpoints distintos pueden usar la misma key sin colisión; mismo endpoint + payload distinto rechaza.
- Prueba requerida: test de dos endpoints con misma key y test de conflicto dentro del mismo endpoint.

AUD-P1-010 - PostingService no valida saldo disponible/pendiente antes de settlement/refund

- Severidad: P1.
- Área: Ledger semántico / Payments sandbox.
- Decisión de continuidad: BLOQUEANTE antes de exponer operaciones de settlement/refund a API o jobs.
- Descripción: releaseSettlement, requestRefund y settleRefund generan asientos contablemente balanceados, pero no verifican que la cuenta debitada tenga saldo suficiente. En cuentas de pasivo credit-normal, un débito mayor al saldo puede dejar balances negativos semánticamente inválidos.
- Evidencia: packages/ledger/src/posting.ts:160-172 delega a twoLegged; twoLegged valida que

- el monto sea positivo y postea, pero no consulta balance_projections.
- Impacto: liquidar más de lo pendiente o refundear más de lo disponible puede crear obligaciones negativas que el balanceo doble no detecta.
- Probabilidad: Media cuando existan APIs/jobs que llamen estos métodos.
- Escenario de falla: releaseSettlement(10000) sobre merchant con pending 1000 produce merchant.pending = -9000.
- Causa raíz: el ledger valida balance contable, no reglas de negocio de saldo mínimo.
- Recomendación: añadir pre-check semántico por operación o una política explícita de saldos negativos permitidos/prohibidos por cuenta. Para merchant.pending, merchant.available, reserves/refunds, prohibir negativo salvo cuenta suspense/recon.differences si se decide.
- Alternativas: permitir negativos solo con razón adjustment/reconciliation y auditoría high-risk.
- Esfuerzo: S/M.
- Criterio de aceptación: settlement/refund que excede saldo falla con error de dominio estable.
- Prueba requerida: golden tests de saldo insuficiente para pending/available/refund liability.

AUD-P2-011 - FSM documentada de pagos no coincide con la tabla mínima payment_intents

- Severidad: P2.
- Área: Payments core / DB schema.
- Decisión de continuidad: INCORPORAR INMEDIATAMENTE antes de implementar F3-01/F3-02.
- Descripción: La tabla fundacional payment_intents soporta cinco estados simples; la documentación de state machines define un modelo más rico para intent/attempt/refund. Este punto refuerza AUD-P2-002.
- Evidencia: packages/db/migrations/0001_foundation.sql:138-140; docs/architecture/payment-state-machines.md.
- Impacto: si se construye payments core sobre la tabla actual, habrá migración correctiva inmediata o pérdida de expresividad.
- Recomendación: antes de crear endpoints de pagos, generar enum único en código y test que compare estados/transiciones contra migración/schema.
- Prueba requerida: meta-test FSM <-> DDL.

AUD-P2-012 - Falta script externo verify-ledger-invariants.sql

- Severidad: P2.
- Área: Ledger / Operaciones.
- Decisión de continuidad: INCORPORAR EN LA SIGUIENTE FASE, antes de cerrar Gate Ledger.
- Descripción: La documentación y production gates piden verificación fuera del ORM, pero no existe scripts/verify-ledger-invariants.sql.
- Evidencia: docs/compliance/production-gates.md:13; ausencia de directorio scripts/ en inventario.
- Impacto: no hay auditoría externa reproducible de balanceo/proyecciones para CI/cron/restore.
- Recomendación: crear script SQL puro que verifique transacciones desbalanceadas por moneda, entries huérfanas, cuenta/tenant/moneda, y proyecciones vs recomputo.
- Prueba requerida: CI ejecuta script y un test de corrupción sembrada lo hace fallar.

AUD-P2-013 - Documentación menciona bucket/column reserved, pero schema/código solo soportan available y pending

- Severidad: P2.
- Área: Ledger / Documentación vs schema.
- Decisión de continuidad: INCORPORAR EN LA SIGUIENTE FASE antes de implementar reserves/disputes.

- Descripción: El chart incluye cuentas de reserva, pero balance_projections y BalanceBucket solo tienen available y pending. Si el diseño requiere bucket reserved, debe definirse antes de reservas/disputas.
- Evidencia: packages/db/migrations/0007_ledger_core.sql:41-48; packages/ledger/src/types.ts:18; documentación de ledger/concurrencia según revisión independiente.
- Impacto: implementación futura de reserves puede improvisar sobre cuentas sin bucket, causando drift semántico.
- Recomendación: decidir: reservas como cuentas separadas sin bucket reserved, o añadir bucket/columna reserved. Actualizar docs y tests.
- Prueba requerida: posting de reserva y recomputo de proyección.

AUD-P2-014 - dbUrlsFromEnv duplica defaults sin protección anti-mezcla

- Severidad: P2.
- Área: Configuración / Tests / Seguridad operacional.
- Decisión de continuidad: INCORPORAR EN LA SIGUIENTE FASE.
- Descripción: packages/db/src/config.ts retorna defaults locales sin validar NODE_ENV; packages/config/src/index.ts sí tiene protección anti-mezcla. Los helpers de test usan dbUrlsFromEnv directamente.
- Evidencia: packages/db/src/config.ts:17-29; packages/db/src/testing.ts:32-38; protección correcta en packages/config/src/index.ts:65-72.
- Impacto: tests o scripts podrían apuntar a defaults locales accidentalmente aunque el entorno pretendido no sea local/test.
- Recomendación: unificar configuración para que helpers pasen por loadConfig o añadir validación equivalente en dbUrlsFromEnv.
- Prueba requerida: NODE_ENV=staging sin URLs explícitas debe fallar en helpers DB.

AUD-P2-015 - API keys usan SHA-256 puro en vez de HMAC con clave de servidor

- Severidad: P2.
- Área: API keys / Defensa en profundidad.
- Decisión de continuidad: INCORPORAR EN LA SIGUIENTE FASE antes de sandbox compartido.
- Descripción: Las API keys tienen alta entropía, por lo que SHA-256 no es un fallo inmediato. Aun así, HMAC-SHA256 con una clave en secret manager daría defensa si se filtra solo la base de datos.
- Evidencia: packages/identity/src/api-keys.ts:78-80.
- Impacto: en filtración de DB, el atacante puede hacer cracking offline sin necesitar un secreto del servidor. La entropía de 24 bytes aleatorios hace improbable el brute force, pero HMAC reduce aún más el riesgo.
- Recomendación: migrar a HMAC-SHA256(master_key, secret) versionado (key_hash_version) o añadirlo antes de datos reales.
- Prueba requerida: key creada con versión nueva autentica; hashes viejos migran/conviven.

AUD-P2-016 - Falta CORS/security headers/OpenAPI/load testing/dependency update automation

- Severidad: P2/P3 según subtema.
- Área: API/Ops/DX.
- Decisión de continuidad: INCORPORAR EN LA SIGUIENTE FASE; no bloquea núcleo financiero interno.
- Descripción: No hay CORS/helmet/OpenAPI/k6/Renovate/Dependabot. No son P0 en pre-producción sin frontend público, pero sí deben existir antes de dashboard/checkout o release externa.
- Evidencia: ausencia de configuración en apps/api/src/app.ts, ausencia de openapi.yaml, ausencia de renovate.json/Dependabot.
- Recomendación: introducir cuando se acerque F3 UI/API pública.

Hallazgos de subagentes re-clasificados o no aceptados

- "Sesiones bearer sin cookie HttpOnly": no se acepta como P0 en la fase actual. Es un riesgo real si se construye dashboard browser y se almacena token en JS, pero hoy no hay UI. Se re-clasifica como P2/P1 futuro: antes de dashboard, decidir cookies HttpOnly+CSRF o bearer con storage/CSP/rotación muy controlada.
- "Sesión no rota tras login": no se acepta como P0. El código crea una sesión nueva en login; no hay sesión pre-auth evidenciada. Revocar todas las sesiones en cada login es una decisión de producto/seguridad, no una obligación general. Step-up sigue siendo bloqueante para acciones sensibles.
- "Registro abierto": no se acepta como P0 mientras no haya sandbox público/producción. Se mantiene como riesgo P2/P1 futuro: en entornos no locales, usar invitación, captcha/rate limit o gating de onboarding.
- "Sin Dockerfile/IaC": no se acepta como P0 para este commit pre-producción. Es deuda operativa P2/P3 antes de staging/producción; no bloquea corregir el núcleo financiero.
- "162 tests verdes confirmados": no se acepta como confirmado por esta auditoría. El subagente lo reportó por lectura/estado documental, pero en el entorno real eslint/vitest no estaban disponibles y no se ejecutó la suite. Se mantiene AUD-P1-008.
- "Password complexity": no se eleva. La política de longitud sin composición puede ser compatible con NIST; falta, eso sí, chequeo de passwords comprometidos antes de usuarios reales.

Backlog adicional derivado del addendum

ID	Prioridad	Título	Continuidad	Talla
AUD-P1-009	P1	Añadir endpoint a idempotency key API	BLOQUEANTE antes de F2-09	S
AUD-P1-010	P1	Validar saldos suficientes en settlement/refund	BLOQUEANTE antes de exponer esas operaciones	S/M
AUD-P2-011	P2	Meta-test FSM <-> DDL de PaymentIntent	INCORPORAR INMEDIATAMENTE antes de F3	S
AUD-P2-012	P2	Script externo verify-ledger-invariants.sql	SIGUIENTE FASE	S
AUD-P2-013	P2	Resolver diseño de bucket reserved	SIGUIENTE FASE	S/M
AUD-P2-014	P2	Unificar protección anti-mezcla en DB config helpers	SIGUIENTE FASE	S
AUD-P2-015	P2	Versionar API key hashing con HMAC server-side	SIGUIENTE FASE	M
AUD-P2-016	P2/P3	CORS/headers/OpenAPI/load/dependency automation	SIGUIENTE FASE	M

Cierre

Fluvia tiene una base técnica prometedora y varias decisiones correctas. La auditoría no recomienda reiniciar ni reemplazar arbitrariamente componentes. Recomienda continuar de forma controlada, cerrando primero los bloqueantes que protegen integridad financiera, multi-tenancy, idempotencia, procesamiento asíncrono y evidencia de verificación. El constructor debe tratar la documentación amplia como diseño y backlog, no como implementación real, hasta que cada componente tenga código, pruebas y evidencia reproducible.